Computer Forensics and Cyber crime

Foundations of Digital Forensics

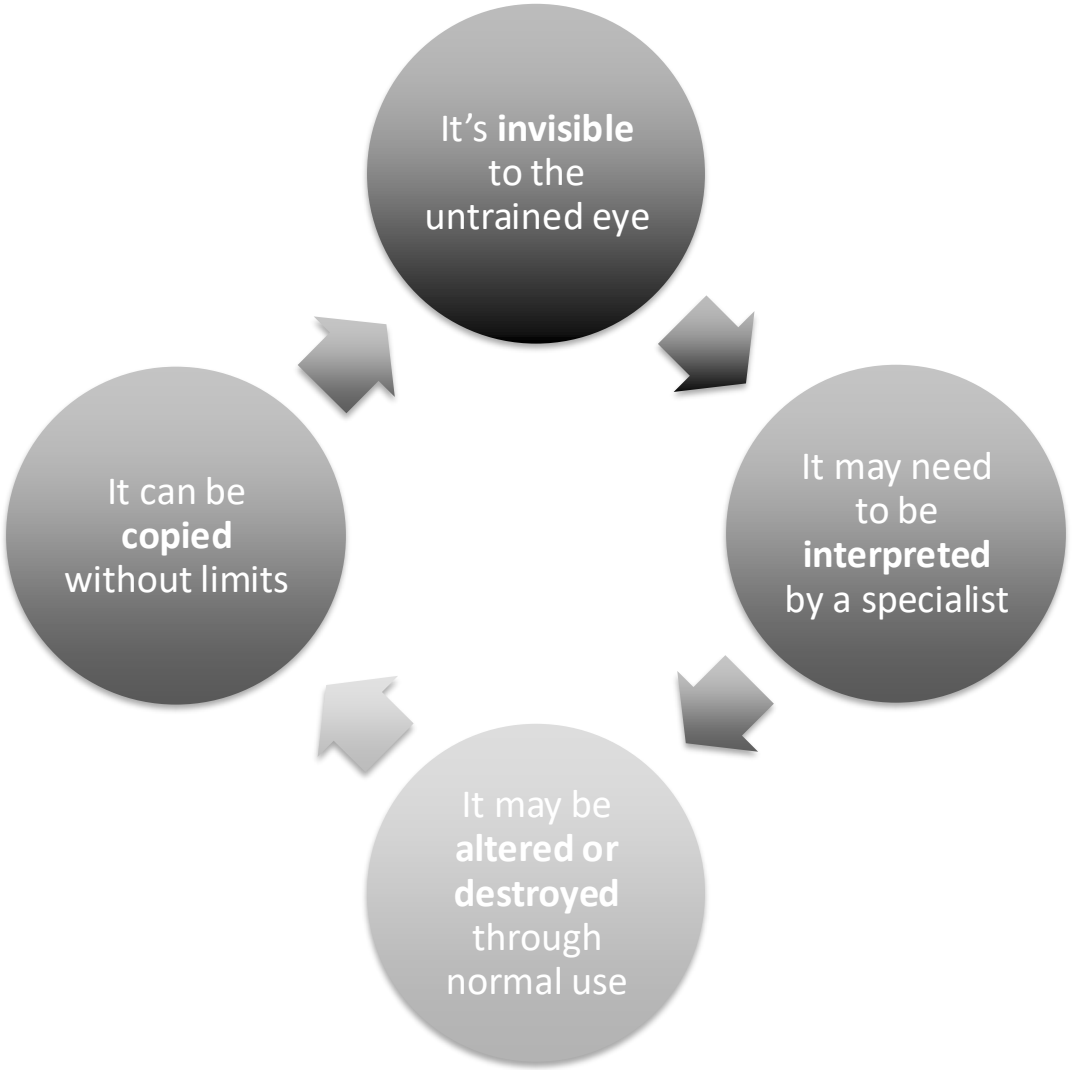
What is Digital/Electronic Evidence?

Digital evidence is ‘any information of evidential value whether memorized or sent in a digital format’ - definition by the Scientific Working Group on Digital Evidence (SWGDE)

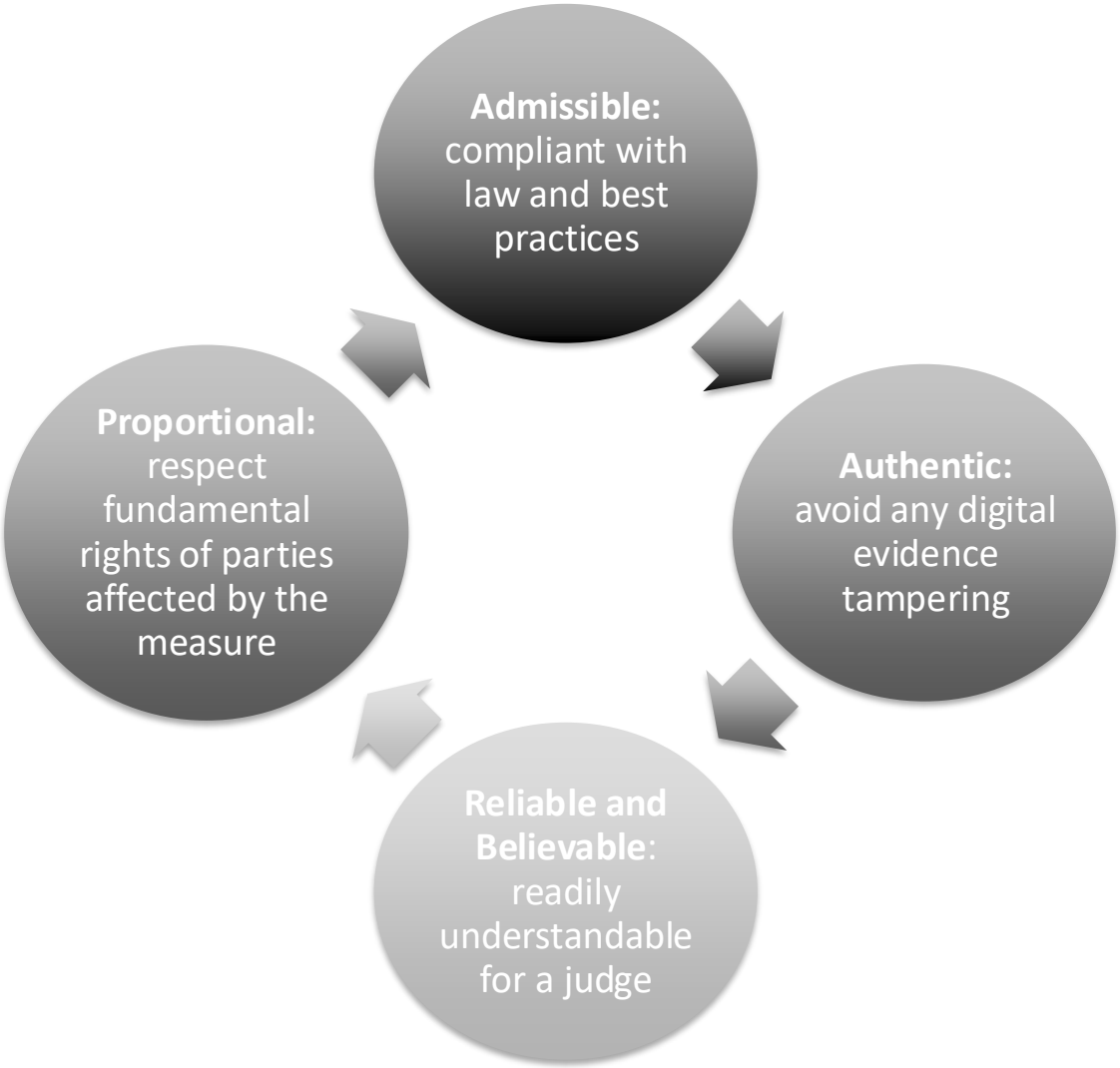
Digital evidence or **electronic evidence** is ‘any probative information stored or transmitted in digital form that a party to a court case may use at trial’ (Eoghan Casey - 2004)

Electronic evidence is information generated, stored or transmitted using electronic devices that may be relied upon in court (Council of Europe - 2013)

What is Digital Electronic/Evidence?



Legal Requirements of Digital/Electronic Evidence?

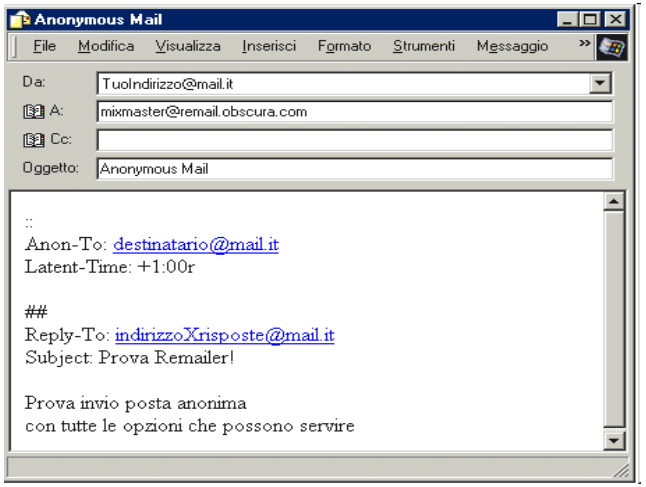


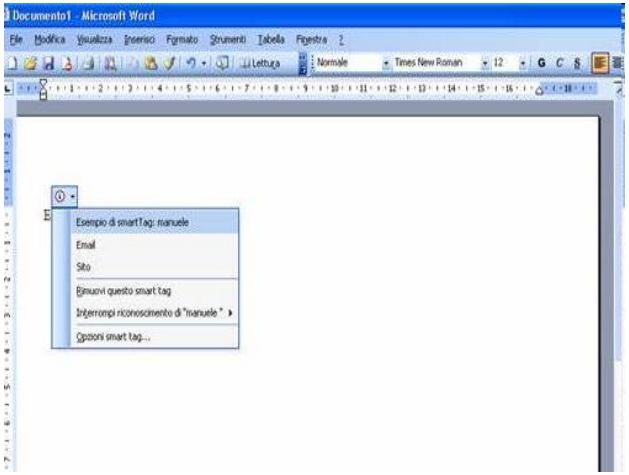
Categories of Digital/Electronic Evidence

There are three types of digital evidence.

Created by man: any piece of digital data that is the result of a step or action taken by a human person. It can be of two types:

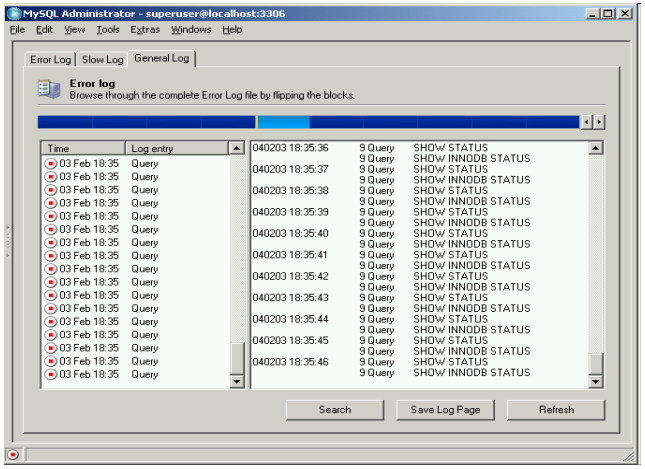
a) Human to human (mail)
b) Human to PC (Word document)

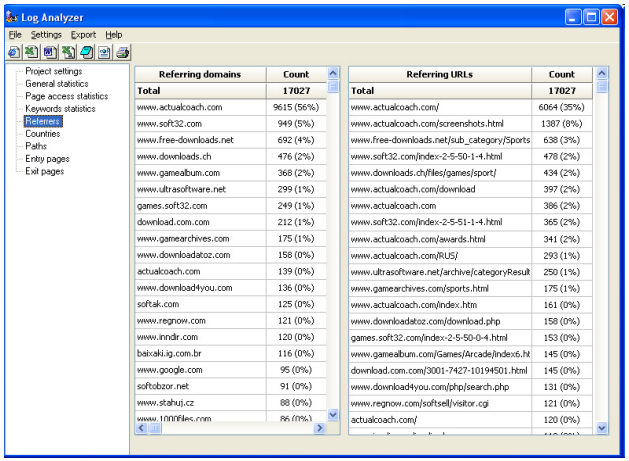




Categories of Digital/Electronic Evidence

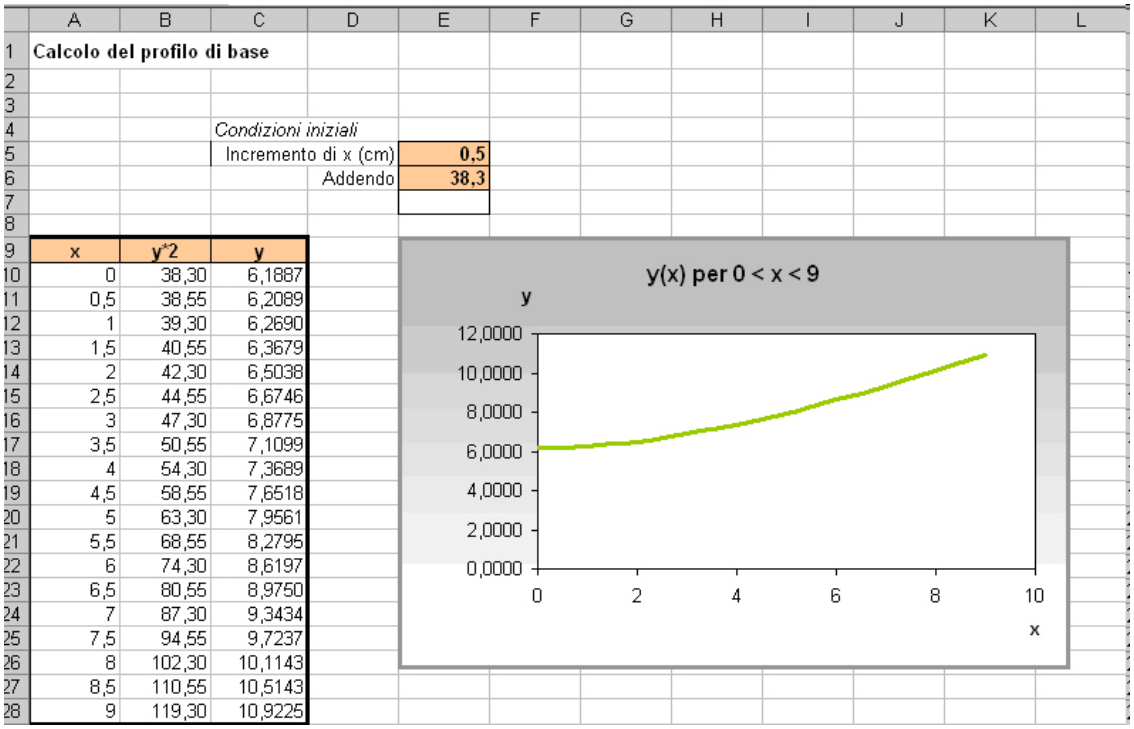
Created independently by the computer: any piece of digital data that is the result of the processing of data carried out by a software in accordance with a specific algorithm and without human intervention (e.g. telephone records or Internet Service Provider logs)





Categories of Digital/Electronic Evidence

Created by both man and the computer: an electronic spreadsheet where data is entered by the human, while the computer works out the result.



Calcolo del profilo di base

Condizioni iniziali

Incremento di x (cm)	0,5
Addendo	38,3

x	y^2	y
0	38,30	6,1887
0,5	38,55	6,2089
1	39,30	6,2690
1,5	40,55	6,3679
2	42,30	6,5038
2,5	44,55	6,6746
3	47,30	6,8775
3,5	50,55	7,1099
4	54,30	7,3689
4,5	58,55	7,6518
5	63,30	7,9561
5,5	68,55	8,2795
6	74,30	8,6197
6,5	80,55	8,9750
7	87,30	9,3434
7,5	94,55	9,7237
8	102,30	10,1143
8,5	110,55	10,5143
9	119,30	10,9225

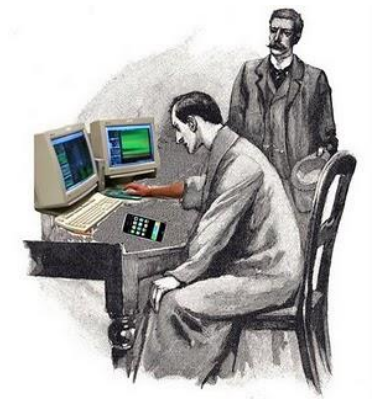
What is Digital Forensics ?

Digital forensics, in a traditional sense, is:

- get hold of evidence without modifying the IT system in which that evidence is found;

- ensure that the evidence acquired in another medium is identical to the original;

- analyse data without modifying it.



The “Big Five” of Digital Forensics (Council of Europe)

Data Integrity	No action taken **should change electronic devices or media**, which may subsequently be relied upon in court.
Chain of Custody	An **audit trail** of all actions taken when handling electronic evidence should be created and preserved.
Specialist Support	If investigations involving search and seizure of electronic evidence it may be necessary to consult **external specialists.**
Appropriate Training	First responders **must be appropriately trained** to be able to search for and seize electronic evidence if no experts are available at the scene.
Legality	The person and agency in charge of the case are responsible for ensuring that **the law and the above listed principles** are adhered to.

Digital Investigation Procedure

Digital Evidence Handling and Media Sanitisation

A technical exploration of NIST SP 800-86, NIST SP 800-88r2, and ISO/IEC 27037 standards for forensic integrity, secure data disposal, and evidence preservation in incident response and investigative contexts.

NIST SP 800-86

Forensics Within Incident Response

01

Collection

Identify and gather relevant data sources whilst maintaining forensic soundness

02

Examination

Extract and assess information from collected data using validated tools

03

Analysis

Interpret findings to draw conclusions about the incident

04

Reporting

Document results with clear chain of custody and integrity verification

NIST SP 800-86 provides methodological guidance for integrating forensic techniques into incident response workflows, emphasising volatile data prioritisation and credible evidence handling through documented integrity controls.

Source: NIST SP 800-86 (2006), §1.2, §3, §3.1.2, §5.2

Integrity Assurance in Digital Acquisition

Core Technical Controls

When evidence may be contested, preserving the original and working exclusively on verified copies becomes paramount. NIST SP 800-86 establishes three fundamental integrity mechanisms:

Live System Considerations

Imaging live systems introduces validation challenges as data continuously changes. Document tool versions, acquisition methodology, and justification for live acquisition versus powered-down forensic imaging.

Chain of custody requires meticulous logging: hardware identifiers, forensic tools with version numbers, hash values, timestamps, and examiner actions throughout the collection process.

Bit-Stream Imaging

Sector-by-sector copy of the entire storage medium

Write-Blocker

Hardware/software preventing writes to original media during acquisition

Cryptographic Hashing

Message digest verification (SHA-256/SHA-512) proving non-alteration

Source: NIST SP 800-86, §3.1.2 (integrity verification), §4.2.2 (write-blocker), §4.2–4.3 (imaging)

NIST SP 800-88R2

Media Sanitisation as Risk Management

NIST SP 800-88r2 (September 2025) redefines media sanitisation not as simple data deletion, but as a **confidentiality risk control** measured against adversary effort levels. The standard establishes a lifecycle approach to protecting data throughout storage media disposition and reuse.

Clear

Logical techniques protecting against simple recovery (overwriting, block erase). Suitable when media remains within controlled environment.

Purge

Physical or cryptographic methods preventing laboratory recovery. Includes cryptographic erase—essential for cloud environments where physical access is unavailable.

Destroy

Physical destruction rendering media unusable. Required when data sensitivity mandates absolute assurance or media cannot be purged.

Source: NIST SP 800-88r2 (2025), §1.1, §3, §3.1 | Note: Revision r1 (2014) was retired 26/09/2025

Sanitisation Assurance and Defensible Documentation

Beyond Technical Execution

NIST SP 800-88r2 distinguishes between **verification** (confirming the sanitisation technique executed correctly) and **validation** (determining whether the outcome adequately addresses the risk).

Certificate of Sanitisation

Each sanitised device requires documented evidence including:

- Device identifiers (serial number, model, storage capacity)
- Sanitisation method and specific technique applied
- Tool name, version, and configuration settings
- Verification and validation results with timestamps
- Responsible parties with roles and authorisations

This documentation establishes audit trail defensibility for compliance reviews, contractual obligations, and legal challenges regarding data disposal.

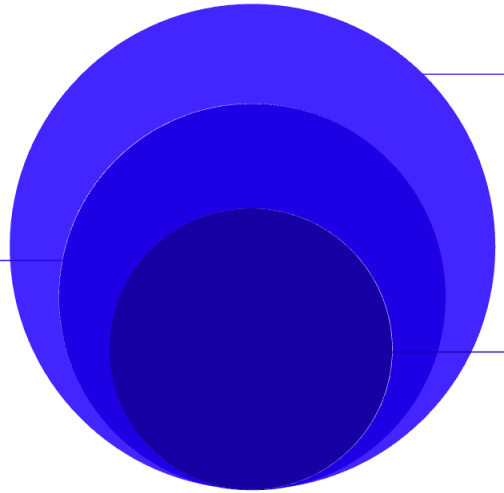
Source: NIST SP 800-88r2, §4.5 (verification/validation), §4.6 (documentation), §4.7 (roles and responsibilities)

ISO/IEC 27037

Digital Evidence First Principles

Foundational Guidelines

ISO/IEC 27037:2012 establishes international methodology for the **identification, collection, acquisition, and preservation** of digital evidence. The standard focuses on initial handling to maintain integrity and authenticity, supporting legal proceedings, cross-jurisdictional cooperation, and internal disciplinary processes.



The standard complements ISO/IEC 27001/27002 security management frameworks, providing forensic readiness procedures that protect evidence value from initial discovery through analysis and potential legal presentation.

Minimise Manipulation

Reduce actions on original evidence; when changes are unavoidable, document justification and methodology

Document Actions

Record all evidence handling steps, environmental conditions, tools used, and personnel involved

Respect Competence

Digital Evidence First Responders (DEFR) recognise limitations; specialists (DES) handle complex analysis

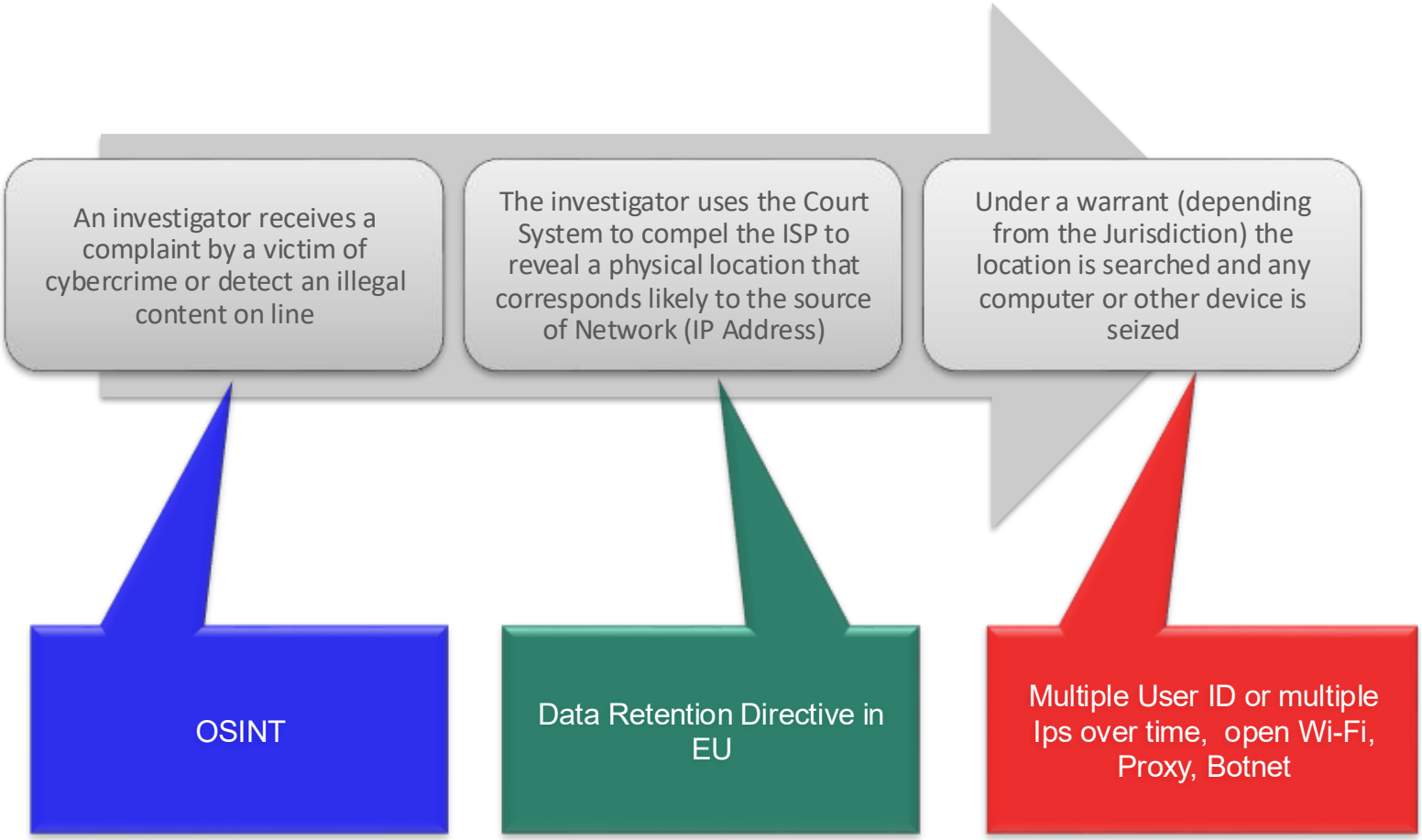
Prioritise by Volatility

Identify evidence according to fragility: RAM, network connections, running processes before persistent storage

Source: ISO/IEC 27037:2012 (scope and principles), §5.4, §5.4.2, §6.1, §6.6 (chain of custody)

Identify the Suspect

The general approach is the following:



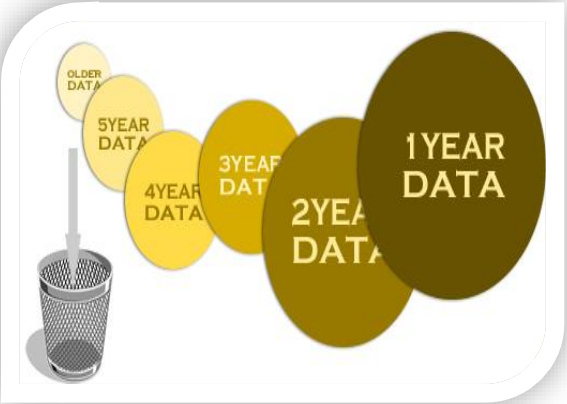
Identify the Suspect: Data Retention

- In the wake of the terrorist attacks in Madrid and London (respectively in 2004 and 2005), the European Parliament issued **Directive 2006/24/EC.**

- **Data retention** (or data preservation) generally refers to the storage of call detail records (CDRs) of **telephony** and **internet traffic** and **transaction data** (IPDRs) by governments and commercial organizations.

- Retention period: from **6** to **24 months**

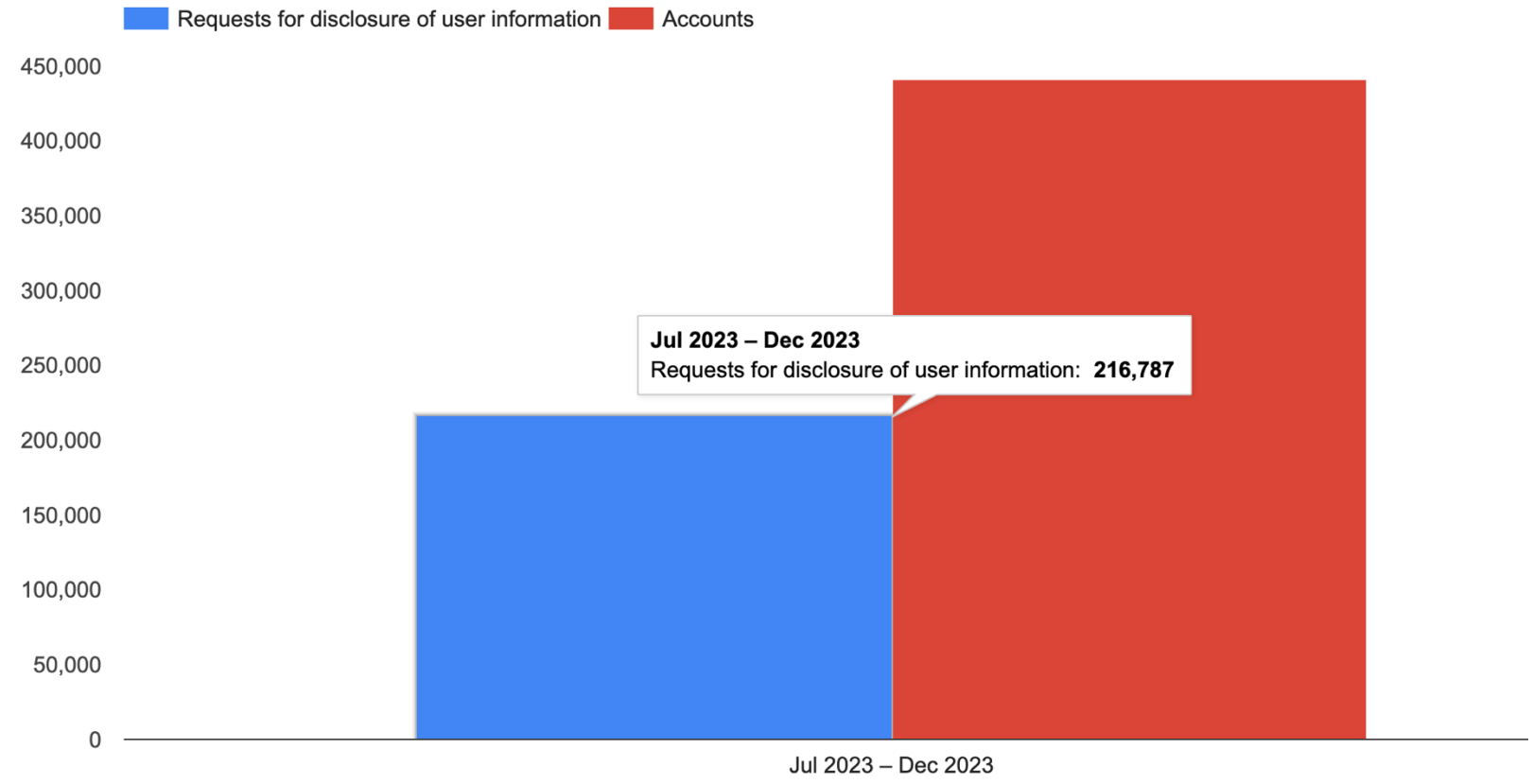
- Scope of application: **serious crime**



Transparency Report: Google

Google | Transparency Report

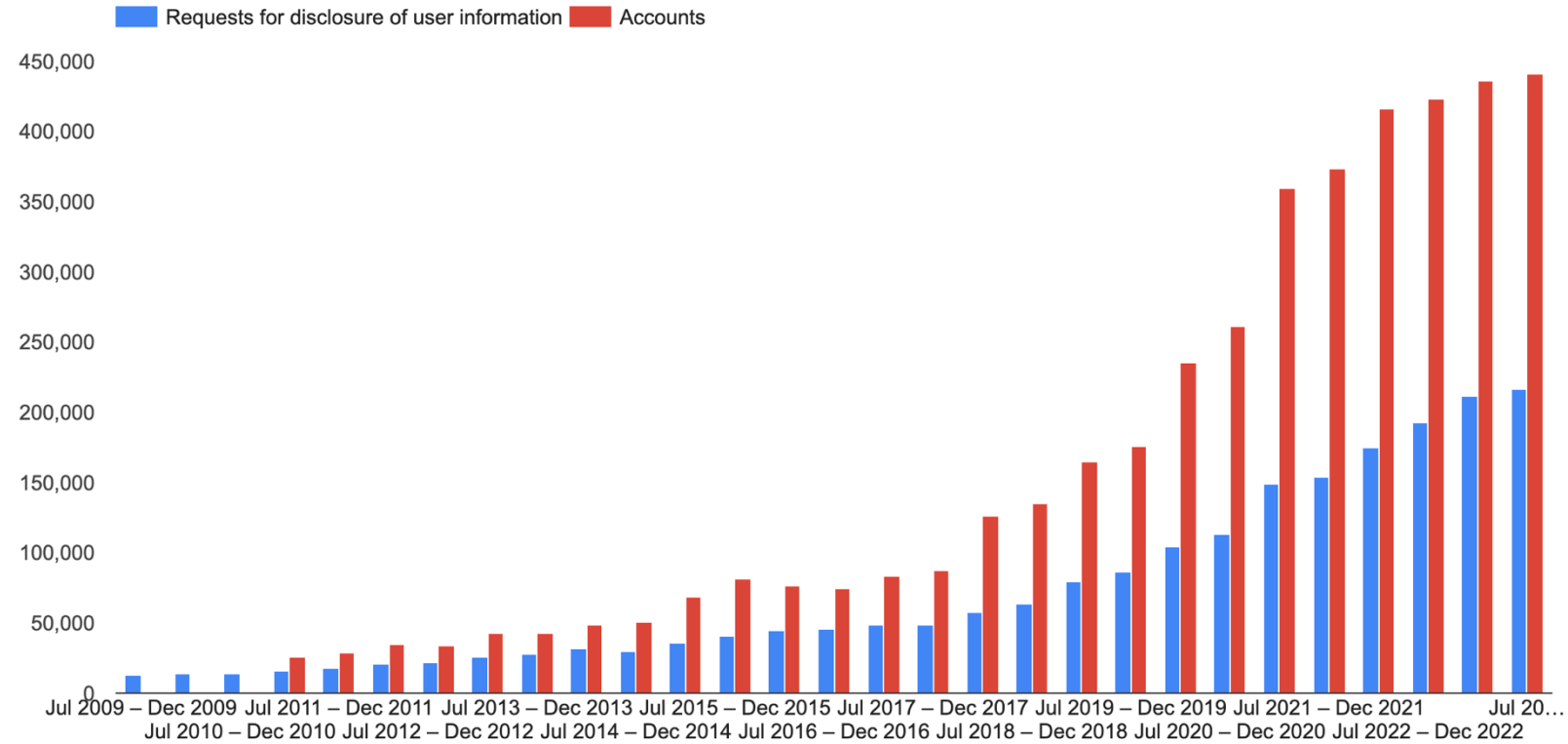
Global



Transparency Report: Google

Google | Transparency Report

Global

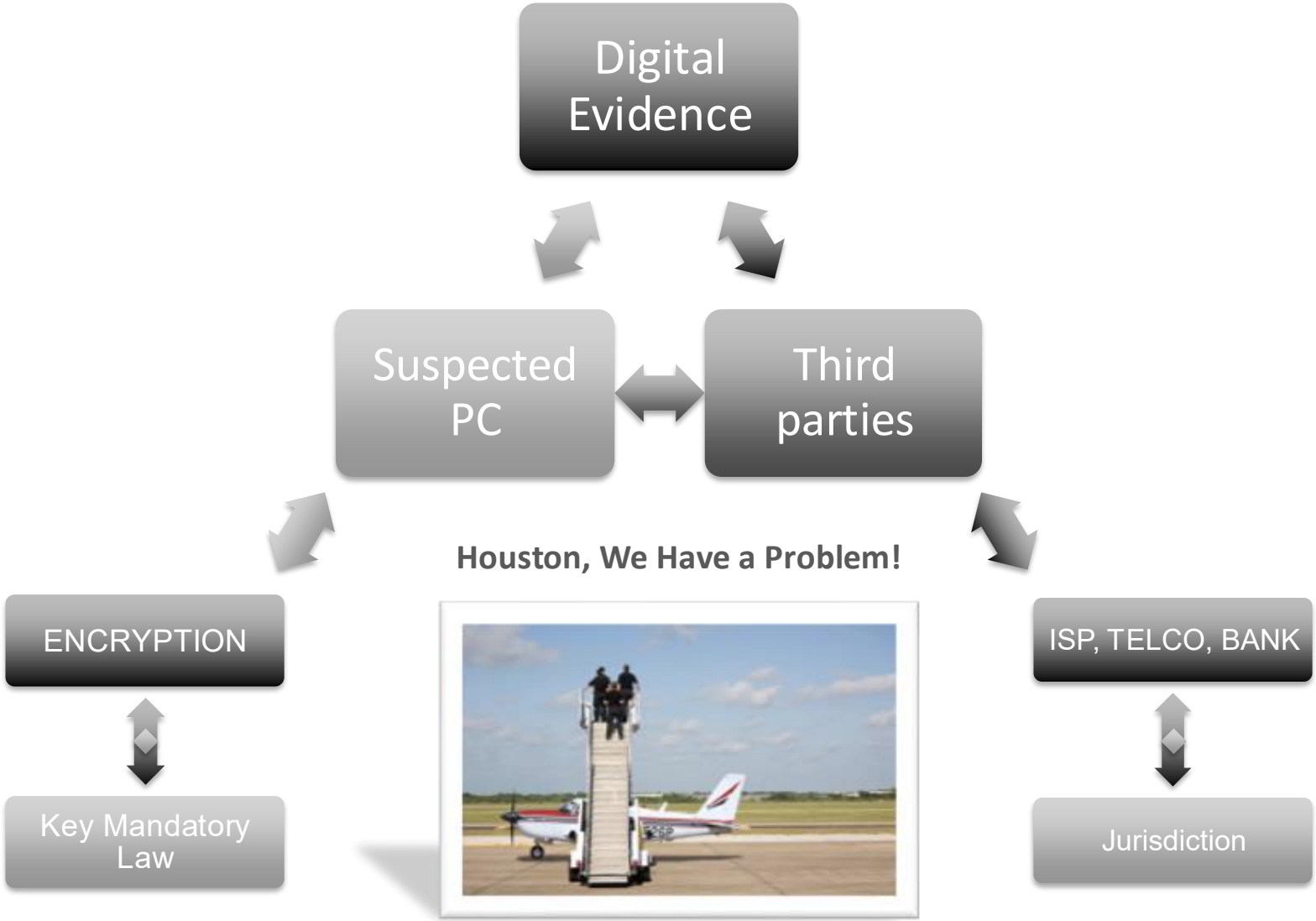


Transparency Report: Twitter

Transparency Report

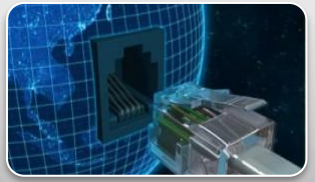
TOTAL ACCOUNT SUSPENSIONS	5,296,870
TOTAL POSTS REMOVED OR LABELED	10,675,980
OVERALL POSTS VIOLATION RATE	0.0123%

Where and how is the digital/electronic evidence hosted?



Why Third Parties are important during Digital Investigations?

Example: a forensics analysis reveals that a cybercrime victim had received a deceptive email that installed a spying software on her/his machine. What to do?



Internet Access Provider

- Could reveal from which place the email was sent

Mail Account Provider

- Could reveal from which places the email account was accessed

Credit Card Company

- Could reveal where the goods bought with a cloned credit card were delivered

Detecting and Seizing Digital Evidence: Cloud Computing

The new challenge with Cloud computing is a loss of data location due to:

-“Data at rest” does not reside on the device.
-“Data in transit” cannot be easily analysed because of encryption.
-“Data in execution” will be present only in the cloud instance

The investigator who wants to capture the bit-stream data of a given suspect image will be in the same situation as someone who has to complete a puzzle, whose pieces are scattered randomly across the globe

Presentation in Court of the Digital Evidence Findings

This stage is of key importance for Prosecutors, Judges and lawyers, as the outcome of the trial will depend not only on results achieved, but also the degree of clarity and comprehension of the report.

Operational recommendations

- Presence of an index
- Presence of a glossary and reference notes if there are any technical terms
- Timeline table and flow charts
- Presentation slides with photos
- Possible video-recording of operations carried out

Presentation in Court of the Digital Evidence Findings: Murtha Case

Privacy and Due Process Rights - Mandatory Key Disclosure Laws

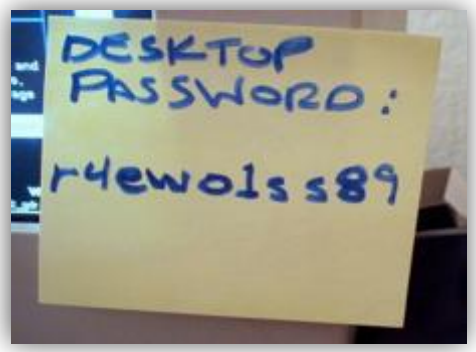
"Mandatory Key Disclosure" is the legislation that requires individuals to surrender cryptographic keys to law enforcement. Nations vary widely in the specifics of how they implement key disclosure laws.

Some, such as **Australia**, give law enforcement a wide-ranging power to compel assistance in decrypting data from any party.

Some, such as **Belgium**, concerned with self-incrimination, only allow law enforcement to compel assistance from non-suspects.

France requires only specific third parties, such as telecommunications carriers, certification providers, or maintainers of encryption services to provide assistance with decryption.

Italy doesn't have a Key Disclosure Law.



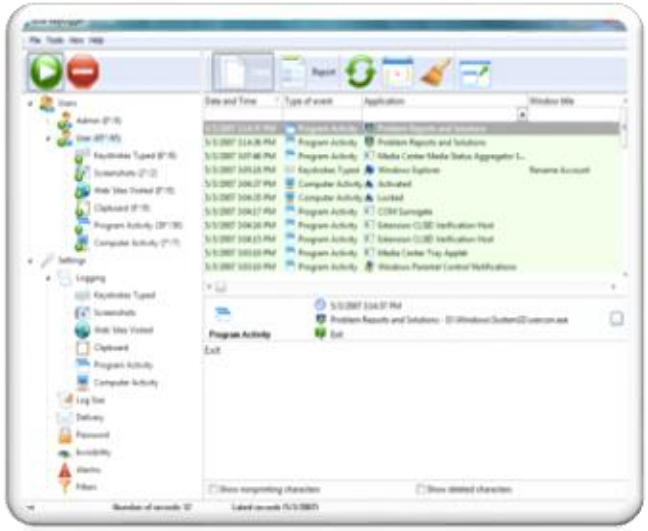
This legislative instrument doesn't work. Why?

1. **Technical reason**: an expert could always find a way to hide a file.

2. **Possible violation of European Convention on Human Rights:** Article 6
Everyone charged with a criminal offence shall be presumed innocent until proved guilty according to law.

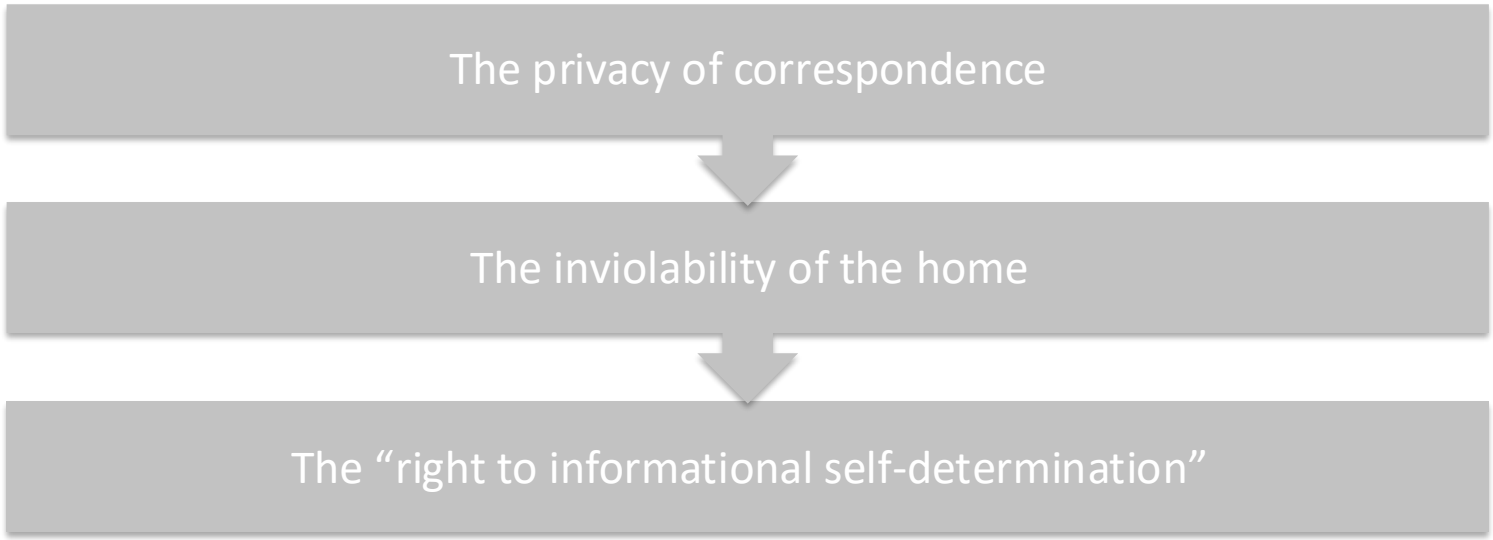
What is a “new” possible solution?

Remote Forensics



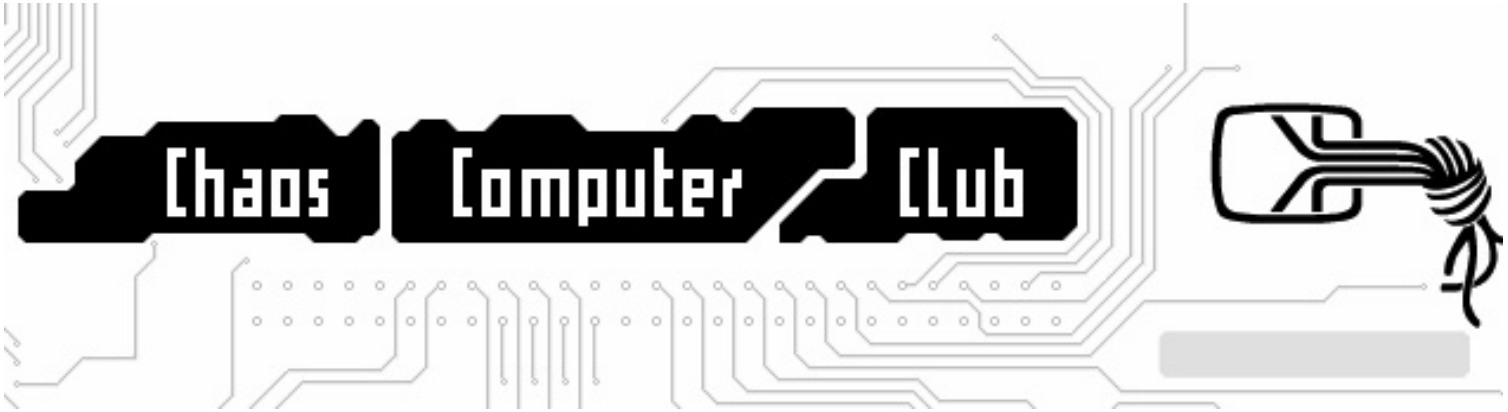
Privacy and Due Process Rights – Remote Forensics

On February 27, 2008 The German Constitutional Court determined that the amendment of NordWestfalia Law was unconstitutional as it violated:



The Constitutional Court establishes a new “**Right to the Confidentiality and Integrity of Information Technology Systems**” (right to the free development of one’s personality), read in conjunction with Article 1.1 GG (right to human dignity).

Privacy and Due Process Rights – After 3 Years :(



Just three years after the ruling by the German Constitutional Court, Germany's Minister of Justice has called for an investigation after authorities in at least four German states acknowledged by using computer spywares to conduct surveillance on citizens (Bavaria, Baden-Wurttemberg, Brandenburg and Lower Saxony).

Privacy and Due Process Rights – Cloud Computing

From a legal standpoint Cloud Computing services have to face these two distinct issues:

Jurisdiction: The "loss of location" of digital evidence in the cloud world creates problem of jurisdiction. With cloud computing, are the documents governed by the law of the state in which they are physically located or by the location of the company possessing them or by the laws of the state where a person resides? Over the last few years, various approaches have been offered to solve this problem.

Privacy: The "lack of control" over the data (cloud clients may no longer be in exclusive control of their data and cannot deploy the technical and organisational measures necessary to respect Data Protection Laws), and the "absence of transparency" (insufficient information regarding the processing operation itself) are the main data protection risks of cloud computing.

Privacy and Due Process Rights – Cloud Computing and Privacy

Privacy and Due Process Rights – Cloud Computing and Jurisdiction

We have 4 possible principles to solve the "loss of location" in a cloudy world:

- **Territorial principle:** the Court in the place where the data is located has jurisdiction.

- **Nationality principle:** the nationality of the perpetrator is the factor used to establish criminal jurisdiction.

- **"Flag principle"**: which basically states that crimes committed on ships, aircrafts and spacecrafts are subject to the jurisdiction of the flag state.

- **"Power of Disposal Approach"**: from a practical point of view, a regulation based on the power of disposal approach would make it feasible for law enforcement to access a suspect's data within the cloud.

Thanks for your attention

Giuseppe Vaciago

Linkedin: http://it.linkedin.com/in/vaciago